

DMARC: Understanding email authentication and how to get it right

Executive summary

Businesses around the world are under constant threat of having their domains spoofed. The bad actors doing this then use those spoofed domains to mask the source of malware or use it in phishing attacks against the business itself. But there is a way to vastly reduce the risk. Domain-based Message Authentication, Reporting, and Conformance (DMARC) is an email authentication protocol. It addresses a vulnerability that bad actors can exploit in organizations using Sender Policy Framework (SPF) and/or DomainKeys Identified Mail (DKIM).

DMARC gives email domain owners the ability to protect their domain from unauthorized use, commonly known as email spoofing. Spoofing means that a domain can be used to send spam or lend legitimacy to messages used for phishing, spear phishing, or whaling. Bad emails are also a conduit for malware to enter an organization. Barracuda research shows that **the average cost of dealing with an email attack** is \$1 million. Email is a door into the business — and not using DMARC leaves that door unlocked and unguarded.

Why you need to fix email vulnerabilities

Email is an essential business function, and many organizations rely on receiving large volumes of emails to operate. But Barracuda's research shows that [75% of organizations surveyed experienced successful email attacks in 2022](#). Email was not originally designed with security in mind, and that has consequences.

In addition to the risks that your business faces from the emails it receives — phishing, spearphishing, and malware, for example — poor email security could lead your organization to gain a reputation as a source of spoofed email, resulting in it being added to lists of prohibited domains. Poor email hygiene could also result in the organization being used as a conduit for nefarious activities. At the very least, poor email practices can get your emails rejected or labelled as spam both by large email services, such as Google and Yahoo — [both of which have recently tightened email security requirements](#) — or by your recipients' corporate email defenses.

How DMARC solves the problem

Email security has evolved over the years, with new practices and protocols added to help fill the gaps. SPF and DKIM are two methods that are supposed to ensure the legitimacy of email messages, but each authenticates only part of an email message.

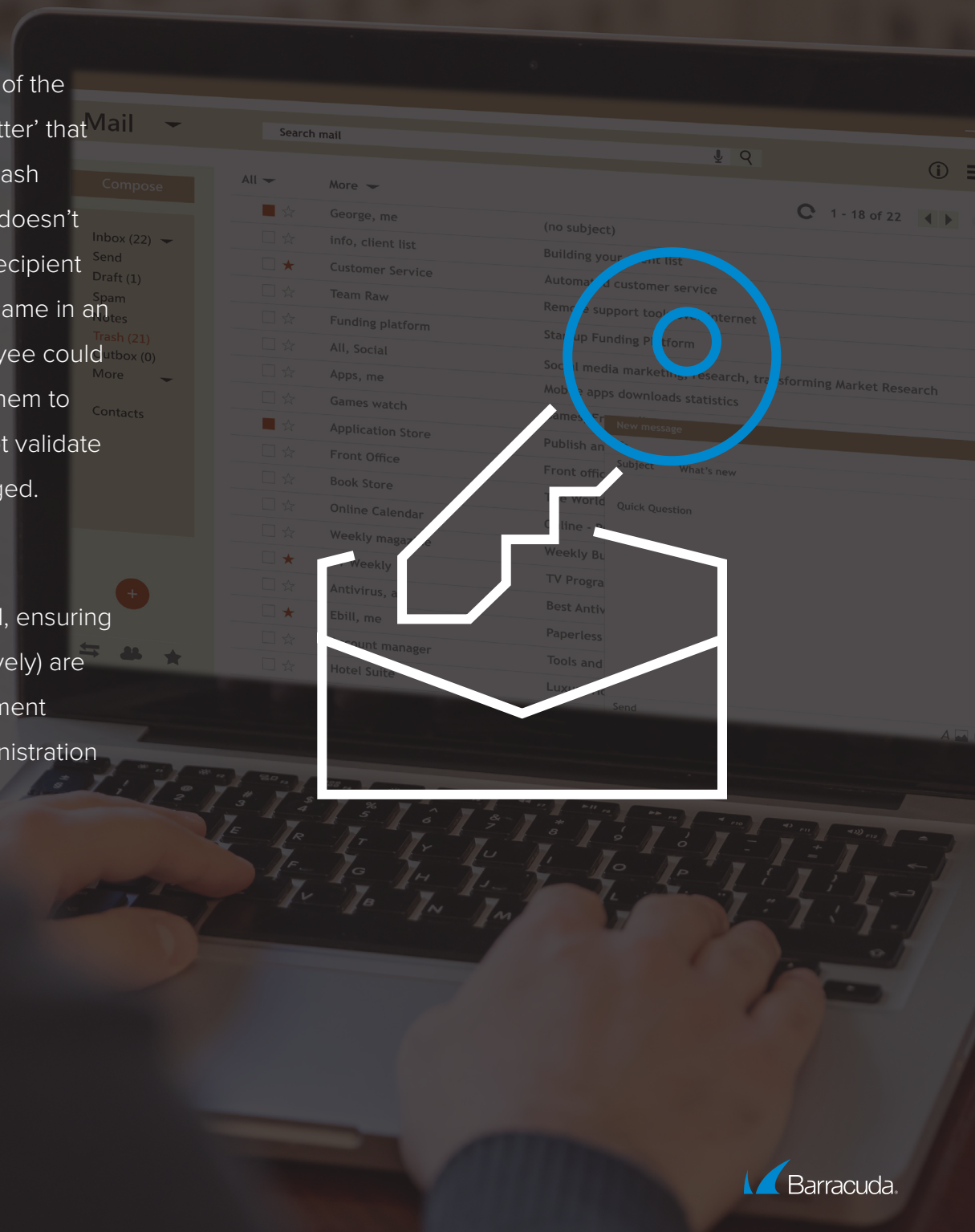
If you think of an email message as a piece of paper mail, Sender Policy Framework (SPF) validates the 'envelope' the message is sent in, checking that it actually came from the sender and domain it claims to be from. It confirms that the email came from a server authorized by the legitimate owner of the domain. However, it doesn't validate or check in any way the contents of the 'envelope.'

A bad actor can abuse any poorly configured domain to send a fraudulent email — the equivalent of a forged letter on a company letterhead — inside an envelope bearing an address different than that on the message inside. This ability is not inherently bad. This is why you can use third-party senders — for example, Salesforce, SendGrid, Mailchimp, and GovDelivery, among others — to send emails that show your organization's domain in the message header.

An attacker could send an authentic-looking email from a recognized domain to staff members claiming that they need to click an included link to update their computer. Once clicked, the link injects malware into the network, compromising network security. If they don't recognize that the email contents aren't a legitimate company communication, your staff can fall prey to this deception.

DomainKeys Identified Mail (DKIM) validates the integrity of the message body's content. It confirms the details of the 'letter' that is inside the 'envelope.' Messages use a cryptographic hash that ensures they have not been altered in transit. DKIM doesn't validate the sender. To use the paper mail analogy, the recipient doesn't know if a letter on company letterhead actually came in an envelope sent from that company. An accounting employee could receive an email that DKIM passes as unaltered asking them to change the payment details for a supplier. DKIM does not validate who sent the message, only that it is has not been changed.

Domain-based Message Authentication, Reporting, and Conformance (DMARC) fills the gap left by SPF and DKIM, ensuring that both 'envelope' and 'letter' (SPF and DKIM, respectively) are aligned. When properly configured, it confirms this alignment automatically and sends status reports to the email administration team so they can check any irregularities.



DMARC is not just another filter

Previous tools to help control invalid email — blocklists, external tags, SPF, and DKIM — were imperfect and provided only partial solutions for a number of reasons that were difficult to address, including:



Many senders have complex email systems that often include third-party email service providers. It is difficult to ensure that every message can be authenticated using SPF or DKIM.



If a domain owner sends a mix of messages, some of which can be authenticated and others which cannot, email receivers are forced to discern between the legitimate messages that don't authenticate and the fraudulent messages that also don't authenticate. Fraudulent messages tend to make their way to the end user's inbox.



It is difficult for senders to validate their email authentication deployments. There are few ways to determine how many legitimate messages are being sent that fail authentication or to determine the scope of the fraudulent emails that are spoofing the sender's domain.



Even when SPF and DKIM are configured properly, email receivers are reluctant to reject unauthenticated messages.

DMARC does more than act as another type of block list. It's a tool for both reporting and enforcement. This gives the organization greater insight into what is happening with its email and its choices in how to respond. After evaluating the SPF and DKIM information of an email, DMARC can instruct mail servers to quarantine emails that fail SPF or DKIM (or both), to reject those emails, or to deliver them.

DMARC delivers benefits in two ways

Reporting	Enforcement
 Identify legitimate senders	 Define a global authoritative policy
 Identify shadow IT running unauthorized email services	 Ensure enforcement
 Identify alignment issues	 Reject impersonations of the protected domain

How Barracuda helps you enforce DMARC and prevent domain spoofing

DMARC has been a standard for about a decade, but [80% of organizations do not have it set up in their email architecture](#).

Many organizations struggle to set up and enforce DMARC on their own, leaving their organization and partners vulnerable to impersonation attacks. With an average organisation having dozens of email senders, companies need to have granular visibility into all traffic that is using their brand to effectively implement DMARC standards.

Barracuda provides DMARC reporting to help organizations set up DMARC enforcement properly and reduce the potential of false-positive enforcements, such as blocking legitimate email or misidentifying a legitimate sender. [Domain Fraud Protection](#) is included as part of Barracuda email protection, as well as a standalone option.

Step 1: [Configuring DMARC reporting on your domain](#)

Either automatically or manually add your domains.

Step 2: [Working with email sources](#)

Identifying IPs and their sources, and organizing into easy-to-read reports.

Step 3: [Enabling DMARC enforcement](#)

With DMARC enforcement, emails from your domain that fail DMARC will be rejected.

Get a free DMARC status analysis of your domains and find threats in your users' inboxes by using [Barracuda Email Threat Scanner](#).

About Barracuda

At Barracuda we strive to make the world a safer place. We believe every business deserves access to cloud-first, enterprise-grade security solutions that are easy to buy, deploy, and use. We protect email, networks, data, and applications with innovative solutions that grow and adapt with our customers' journey. More than 200,000 organizations worldwide trust Barracuda to protect them — in ways they may not even know they are at risk — so they can focus on taking their business to the next level. For more information, visit barracuda.com.

